

LoadLead Platform E2E Audit v6

Date: 2026-07-14 · **Author:** Platform Engineering · **Scope:** backend (Express/TS/DynamoDB), frontend-v2 (React/Vite), infra (Terraform/OpenTofu), across dev / staging / prod. Six parallel dimensions: backend test suite, frontend, environment parity, business-logic, live smoke, security/IAM.

1. Executive summary

The platform is well engineered and, at today's data volume, running correctly: 772/772 backend tests pass with zero flakes, the frontend is clean and the blank-page regression cannot recur, prod is healthy and hardened, and the cryptographic trust boundary (JWT alg pinning, KMS-encrypted TIN, webhook signatures, secrets hygiene) is largely sound. The boot guard is fail-closed and fully wired.

The risk this round is concentrated in **authorization** and **scale**. The adversarial passes found **3 CRITICAL** issues: one latent data-correctness bomb on money/legal paths, and two live privilege/tenant-isolation holes. None require broken crypto to exploit; they are missing ownership checks, an over-permissive signup, and an un-paginated query helper.

Findings by severity

Severity	Count	Theme
CRITICAL	3	Un-paginated DB reads truncate money/legal data; self-signup as ADMIN; cross-tenant org takeover
HIGH	13	Object-level authorization (IDOR) on charges/factoring/receiver/BOL/org; unauth billed maps proxy; Didit fail-open; hot-path scan DoS; presigned-upload abuse; admin tier-drift; axios/deps; SNS verifier untested; dev capacity table pointer
MEDIUM	~16	AML skippable; unvalidated maxCapacityLbs; accessorial double-charge; silent-failure admin fetches; stop-event injection; IDOR on policy docs; email-bomb; upload MIME; N-scan fan-out; token logging; route/webhook test gaps
LOW	~15	Capacity same-ms nondeterminism; JWT base-role TTL; ErrorBoundary/lazy hygiene; legal-hold wiring; deps; staging tfvars dead values

The 3 CRITICALs

- 1. **BL-C1 - Database.scan / query never paginate.** Both helpers issue one command and return `result.Items`, ignoring `LastEvaluatedKey` (`config/database.ts:94-137`). DynamoDB caps a page at 1 MB. Once the forever-growing append-only tables cross 1 MB, three paths silently return wrong answers, with no error: court-ordered **payout intercepts** (a levied carrier gets paid in full), **factor payee routing** (funds to the wrong party), and **legal holds** (a held record becomes deletable). Latent today; fires with data growth.
- 2. **SEC-C1 - Self-registration as platform ADMIN.** `POST /api/auth/signup` accepts an attacker-chosen `role`, and the validator allows `ADMIN` (`routes/auth.ts:52`, `utils/validators.ts:16`). `resolvePlatformRole(undefined)` then grants `STAFF_ADMIN` across every tier. Currently gated behind the beta wall (`BETA_MODE` is on in prod), so the immediate exposure is "any beta-cohort member can become full platform admin"; with `BETA_MODE` off it is fully unauthenticated.
- 3. **SEC-C2 - Cross-tenant org takeover (IDOR/BOLA).** Org member routes authorize the caller against the path `:orgId` but act on a globally-resolved `:membershipId` with no `target.orgId === orgId` check (`routes/org.ts:308,347`; `orgService.ts:303,354`). An attacker who owns a throwaway org can promote a colluder to `OWNER` of any other org, or remove that org's real owner.

Top fixes to land first

SEC-C1, SEC-C2, and SEC-H7 (Didit fail-open) are each a single-file, low-risk patch with outsized blast-radius reduction. BL-C1 is a shared-helper change (add a `LastEvaluatedKey` loop) plus a few GSIs. These four are the recommended immediate sprint (Section 4).

2. Severity-ranked findings (consolidated, deduped)

Two findings were reported independently by the business-logic and security passes and are merged here (Didit fail-open; hot-path scans), which raises confidence.

CRITICAL

ID	Finding	Where	Dimension
C1	DB scan/query no pagination -> silent truncation of intercepts / factoring / legal holds	config/database.ts:94-137	Business-logic
C2	Self-signup as ADMIN (privilege escalation to full compromise)	routes/auth.ts:52 , utils/validators.ts:16	Security
C3	Cross-tenant org takeover via unbound <code>membershipId</code> (IDOR)	routes/org.ts:308,347	Security

HIGH

ID	Finding	Where	Dimension
H1	Accessorial charge approve/adjust/dispute on any load's charge (financial IDOR)	accessorials.ts:205,216,236	Security
H2	Factoring invoice package/export cross-tenant read + exfiltration	factoring.ts:395,409,231	Security
H3	Receiver reads any load by id	receiver.ts:41	Security
H4	BOL creation on another shipper's load	bol.ts:64	Security
H5	Org member suspend/reinstate: same tenant-binding gap	org.ts:369,391	Security
H6	<code>/api/maps/*</code> unauthenticated, unthrottled, billed proxy (billing/availability DoS)	index.ts:321 , maps.ts:68	Security
H7	Didit webhook fails OPEN when secret unset (forge VERIFIED) [also found by business-logic]	verification.ts:382	Security + Business-logic
H8	Hot-path profile lookups (driver/shipper/receiver) full-table scan -> null at scale + DoS [also found by business-logic]	driverService.ts:119 , shipperService.ts:71 , receiverService.ts:42	Security + Business-logic
H9	Presigned-PUT uploads: no size/MIME cap, client Content-Type, no ownership, public bucket	driver.ts:261,275 , attestation.ts:48	Security
H10	Admin grant/revoke on bare <code>requireAdmin</code> (intra-staff tier escalation)	admin.ts:79,87	Security
H11	Dependency vulns: axios SSRF/proto-pollution, form-data CRLF, path-to-regexp ReDoS (all fixAvailable)	backend package.json	Security
H12	SNS webhook signature verifier has zero test coverage (SSRF allowlist + X.509)	services/snsVerify.ts	Backend tests
H13	Dev missing <code>DYNAMODB_CAPACITY_STATE_EVENTS_TABLE</code> -> resolves to PROD table name	envs/dev/main.tf , environment.ts:71	Env parity

MEDIUM (condensed; full detail in dimension files)

ID	Finding	Where
M1	AML gate treats never-screened (undefined) as passing	verification.ts:93
M2	maxCapacityLbs unvalidated on PUT -> breaks integer invariant + unlimited capacity board	driver.ts:87 , driverService.ts:143
M3	Accessorial double-charge when policy edited after charge computed	accessorialChargeService.ts:96
M4	Silent-failure fetches in admin consoles (misleading empty state on error)	BetaProgramDashboard.tsx , LiquidityDashboard.tsx
M5	Accessorial charge listing has no role guard	accessorials.ts:195
M6	Stop-event injection on unassigned loads (fabricate/suppress detention)	accessorials.ts:50,79
M7	Compliance policy-doc read/sign IDOR	compliance.ts:358,369
M8	Unauthenticated waitlist email-bomb	beta.ts:49
M9	COI/LOA/shipper-policy upload: no MIME allowlist + 100KB json cap (also a functional bug)	compliance.ts:204,228,329
M10	Dashboard N x full-Loads-scan fan-out	ownerOperator.ts:507 , org.ts:769
M11	Invitation accept not bound to invite.email ; revoke not org-bound	orgService.ts:659 , org.ts:586
M12	Load mass-assignment via unfiltered req.body spread	loadService.ts:173
M13	Invitation tokens + full Didit event body (PII) logged in cleartext	orgService.ts:653 , verification.ts:407
M14	Canopy webhook route + capacity route untested end-to-end (raw-body / role gate)	canopyWebhook.ts , routes/capacity.ts
M15	"False-green" negotiation tests hit real DynamoDB; outbox persistence unverified	negotiationDispatch.test.ts , negotiationEsign.test.ts
M16	Untested services: calcUsableVolume geometry, complianceGather	capacityService.ts , complianceGather.ts

LOW (condensed)

Capacity fold same-ms nondeterminism (add a seq tiebreaker, haulerCapacityService.ts:51); base role trusted from a 7-day JWT with no revocation (TB1); legal-hold assertDeletable thin + RetentionService unwired; BOL reads nonexistent driverId (use assignedDriverId); single root ErrorBoundary; ineffective lazy() on PrivateBetaLanding; backend /api/admin mount ordering foot-gun; CORS returns hard 403 on /api/health for disallowed origins; staging .auto.tfvars sets dead BETA_MODE/NODE_ENV; prod fail-closed invariants enforced out-of-band (not IaC); moderate deps (qs, uuid, dompurify); no lockfile; AWS SDK node-22 deprecation (before Jan 2027); admin routes lack route-level tests.

3. Environment parity matrix

62 table slots (52 prefix-derived config + 10 service-direct). Single divergence:

Table slot	dev env-var	staging env-var	prod table
CapacityStateEvents	MISSING -> resolves to LoadLead_CapacityStateEvents (PROD)	LoadLead-Staging-CapacityStateEvents (prefix)	LoadLead_CapacityStateEvents
all other 61 slots	in parity	in parity	in parity

Physical tables exist in all three envs. The CI parity checker (scripts/check-table-env-parity.mjs) exits 1 on this one gap. The boot guard would refuse to boot a hosted dev env that resolved a prod name, so real blast radius is contained (dev has never been applied and runs on local DynamoDB). Cross-env integration modes (stub/sandbox vs live), feature flags, and prefixes are all intentional and correct. Staging backend is currently PAUSED (ASG at 0 via the toggle); its static frontend stays served.

4. Course of action (prioritized)

COA-1 - Immediate (this week): the two live authorization CRITICALs + one HIGH

- **SEC-C1:** allowlist `/signup` to non-privileged roles only; reject ADMIN/CARRIER_ADMIN unconditionally; `resolvePlatformRole` returns null (not STAFF_ADMIN) for users with no explicit tier. Add a regression test.
- **SEC-C2 + H5:** centralize a `target.orgId === orgId` assertion in the four member routes (PATCH/DELETE/suspend/reinstate) and the four service methods.
- **SEC-H7:** Didiit webhook returns 401 in production when the secret is unset (mirror Canopy); bootGuard asserts the secret's presence.
- Each is single-file, low-risk, staging-first. Ship together.

COA-2 - Near-term (next sprint): the data-correctness CRITICAL + IDOR cluster

- **BL-C1:** add a `do/while (LastEvaluatedKey)` loop to `Database.scan` and `Database.query`; add `carrierId / invoiceId / entityId` GSIs and move the intercept / factoring / legal-hold resolvers to `query`. Add a >1MB pagination test.
- **IDOR sweep:** apply the existing `assertCallerActsForLoad` / load-party pattern to H1 (charges), H2 (factoring invoices), H3 (receiver), H4 (BOL create), plus M5/M6/M7 (charge listing, stop events, policy docs).
- **SEC-H8 / H2 (perf):** add `userId-index` GSIs for driver/shipper/receiver profile lookups and switch to `query`.

COA-3 - Hardening: DoS, uploads, deps, data integrity

- **SEC-H6:** authenticate + rate-limit `/api/maps/*`; cap the Google key daily spend.
- **SEC-H9 / M9:** `createPresignedPost` with server-pinned Content-Type + content-length-range; verify load-party; keep buckets private.
- **SEC-H11:** `npm audit fix` (axios >= 1.16.0 first).
- **SEC-H10:** raise admin grant/revoke to DESTRUCTIVE_TIER.
- **BL-M2 (capacity):** validate `maxCapacityLbs` as a non-negative integer with a sane max, at the route and in `updateProfile`.
- **BL-M1 (AML), BL-M3 (double-charge), M11 (invite email-bind), M12 (mass-assignment allowlist), M13 (redact token/PII logs).**

COA-4 - Parity, tests, hygiene

- **H13:** migrate dev to `DYNAMODB_TABLE_PREFIX = local.prefix` (staging pattern); re-run the parity checker to green.
- **H12 / M14 / M15 / M16:** add tests for `snsVerify`, canopy + capacity routes, and mock the outbox in the two false-green negotiation tests; add a lockfile.
- **BL-L1 (capacity):** add a monotonic `seq` tiebreaker to the capacity fold.
- Frontend: `.catch` on the admin-console loaders; consider a per-route `ErrorBoundary`.

5. Recommendations & next steps

1. **Treat SEC-C1 and SEC-C2 as security incidents** even though BETA_MODE gates C1 today: verify no unexpected ADMIN accounts exist in prod (audit the users table for `role=ADMIN` with no legitimate platformRole), then land COA-1.
2. **Do not let the intercept / factoring / legal-hold tables grow further without BL-C1.** They are the exact tables where silent truncation has legal and financial consequence; add a CloudWatch item-count alarm at, say, 5,000 rows as an interim tripwire until pagination ships.
3. **Add an authorization contract test** (the Cypress `authz-cross-tenant` spec exists) covering the IDOR cluster so these do not regress.
4. **Resume staging** and re-run the live smoke to confirm prod/staging parity (blocked this round by the pause).
5. Keep shipping staging-first with admin-merge; every COA item above is scoped to a single team's lane (mostly Identity/Access and Settlements) and can be parallelized.

6. Confidence: what was verified clean

Negotiation state machine (first-accept-wins, e-sign gate, integer cents, Load row never mutated); capacity deduct/restore idempotency; money primitives (integer cents, half-up rounding); reconciliation/intercept idempotency keys; Canopy signature (raw-body HMAC, replay window, rejects unsigned in prod - the previously-open blocker is resolved); JWT alg pinning; no DynamoDB expression injection; W9 TIN KMS envelope

encryption; crown-jewel W9/COI/LOA reads gated; cookies httpOnly+Secure+SameSite; boot guard fail-closed and wired before listen; frontend chunk shape known-good; API contract fully matched; no secrets in source/bundle/infra.

7. Appendix - dimension detail

Full evidence per dimension: `01-backend-tests.md` , `02-frontend.md` , `03-env-parity.md` , `04-business-logic.md` , `05-live-smoke.md` , `06-security-iam.md` (this directory).